Microsoft Entra — Secure Cloud Identity Reference Architecture

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Microsoft Entra: Secure Cloud Identity Reference Architecture 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 6

Outcome . . . 6

1. Solution Overview — Microsoft Entra: Secure Cloud Identity Reference Architecture 6

What a reference architecture is (and what it is not) . . . 6

Why identity is the control plane . . . 6

The six design domains . . . 6

How the blueprint relates to the builds (this is a design product) . . . 7

The design method — Assess, Configure, Pilot, Validate, Expand . . . 7

Naming and standards the design defines . . . 8

Authentication and connections used . . . 8

What you can control . . . 8

Benefits . . . 8

Limitations (be honest with buyers) . . . 9

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture 9

2.1 Read-only access to the current tenant (for Assess) . . . 9

2.2 Microsoft Graph PowerShell SDK and the Az module . . . 10

2.3 Access to Entra sign-in and audit logs (for the posture KQL) . . . 10

2.4 A current licensing and product inventory . . . 10

2.5 Named decision owners (the design cannot be made for them) . . . 10

2.6 Inventory of existing identity controls (avoid re-deciding what exists) . . . 11

2.7 Break-glass accounts (design prerequisite, not a build here) . . . 11

2.8 A place to author the design artifacts . . . 11

Checklist . . . 11

Global Requirements — Entra ID Solutions (category-level) 12

G1. Microsoft Entra ID tenant . . . 12

G2. Entra ID licensing (P1, P2 where noted) . . . 12

G3. Administrative roles . . . 12

G4. Break-glass (emergency access) accounts . . . 12

G5. Healthy on-premises Active Directory . . . 12

G6. An Entra Connect host server . . . 13

G7. UPN / domain hygiene . . . 13

G8. Network access to Microsoft cloud endpoints . . . 13
3. Design & Decision Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture 13
Stage 1 (Assess) — inventory the current identity posture . . . 14
Stage 2 (Configure) — design the six domains and record the decisions . . . 14
Stage 3 (Pilot) — design review with the decision owners . . . 17
Stage 4 (Validate) — check the design against gates and the tenant . . . 17
Stage 5 (Expand) — finalize and roadmap . . . 17
5. Testing Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture 18
Test 1 — Assess evidence is complete . . . 19
Test 2 — Every existing control is classified . . . 19
Test 3 — The Decision Record covers all six domains . . . 19
Test 4 — Each ADR is complete and defensible . . . 19
Test 5 — License and preview dependencies are flagged . . . 19
Test 6 — Break-glass standard is in the design . . . 19
Test 7 — The blueprint validates against the tenant . . . 19
Test 8 — Every domain has a build cross-reference . . . 19
Test 9 — The roadmap is phased and gated . . . 20
Test 10 — Decision Record is frozen and living . . . 20
Pass/fail gate . . . 20
6. Troubleshooting Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture 20
A. Assessment scripts fail to connect or read . . . 20
B. Posture / KQL evidence is thin or empty . . . 21
C. Licensing reality does not match the design's assumptions . . . 21
D. A decision has no owner / the design stalls . . . 22
E. The design conflicts with an existing control . . . 22
F. `ENTARCH-Validate.ps1` flags gaps . . . 22
G. The blueprint is treated as the build (scope confusion) . . . 22
H. Diagnostics quick reference . . . 23
I. When to escalate . . . 23
7. Best Practices — Microsoft Entra: Secure Cloud Identity Reference Architecture 23
Where to go next . . . 24
8. Deliverables Summary — Microsoft Entra: Secure Cloud Identity Reference Architecture 25
Documentation . . . 25
PowerShell scripts (all read-only; Microsoft Graph / Az + KQL) . . . 25
What the buyer receives . . . 26
Outcome . . . 26

Appendix A — PowerShell Scripts 27

Executive Summary — Microsoft Entra: Secure Cloud Identity Reference Architecture

White-label · Entra ID Solutions

Identity is the control plane of a modern Microsoft cloud estate, and it is the one plane that, built ad hoc, quietly accrues risk: permanent Global Admins nobody remembers granting, RBAC sprawl, guests that never leave, no Zero Trust design, and rework every time a new project bolts something on. This solution is the antidote — a **reference architecture**: a documented, defensible design for a secure Entra cloud identity foundation, plus a **decision record** that captures why each choice was made and a **phased roadmap** that sequences the build.

This is a **design and blueprint deliverable, not a step-by-step deployment**. It gives an architect or a competent admin a repeatable method to assess the current identity posture, make the core architecture decisions (tenant topology; the human / workload / external identity model; the Zero Trust access design; the privileged access model; the identity governance model; and hybrid / coexistence), record those decisions, and turn them into a sequenced roadmap. The individual builds — Conditional Access, Identity Protection, PIM, PAW, governance, Global Secure Access, app migration — are delivered by the adjacent implementation solutions this blueprint points to. **This is the blueprint; they are the builds.**

What you get

• A plain-language Solution Overview of what a reference architecture is, the six design domains, and how the blueprint relates to the implementation solutions that execute it.

• A Requirements Guide with verify / implement-if-missing for every solution-specific input the design work needs (posture data, decision owners, tooling).

• A Design & Decision Guide — an ordered method that produces three named artifacts: the **Architecture Design Document**, the** Decision Record **(a numbered set of architecture decisions,** `ADR-0nn`**), and the** phased Roadmap** — each cross-referenced to the build solution that implements it.

• Five read-only PowerShell scripts (Microsoft Graph / Az) plus KQL that inventory the current identity posture — humans, workloads, external identities, privileged access, Conditional Access, licensing — so the design is grounded in evidence, not assumption, and a validation script that checks the tenant against the target-state blueprint.

• Testing and Troubleshooting guides for a rigorous, review-gated design process.

What this delivers

A documented, board-defensible Entra identity architecture: a target-state design across six domains, a numbered decision record with the rationale and the license/preview caveats behind each choice, a canonical naming and admin-tiering standard the builds will reuse, and a phased roadmap that sequences the implementation solutions — so the identity foundation is designed once, deliberately, before the risk and rework accrue.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

An identity foundation that is designed rather than accreted — topology, identity model, Zero Trust access, privileged access, governance, and hybrid coexistence decided on purpose, recorded, and roadmapped, with every build cross-referenced to the solution that delivers it.

> *Several target-state controls in this architecture depend on specific licensing — Entra ID P1/P2, Entra ID Governance, Global Secure Access, Verified ID — and some capabilities are in preview. Where a decision depends on a license or a preview feature this blueprint flags it explicitly and says *verify current availability in your tenant*. The regulatory, data-classification, and change-approval determinations remain the customer's to make; the architecture provides the technical design, not those decisions.*

1. Solution Overview — Microsoft Entra: Secure Cloud Identity Reference Architecture

What a reference architecture is (and what it is not)

A reference architecture is a **documented design**: a set of deliberate decisions about how your identity foundation is structured, why each decision was made, and in what order it should be built. It is the drawing, not the building. This solution produces three artifacts — an **Architecture Design Document**, a **Decision Record** (a numbered log of the choices and their rationale), and a **phased Roadmap** — and hands the actual construction to the implementation solutions it cross-references.

That separation is the point. Building Conditional Access, PIM, governance, and hybrid sync without a design first is how tenants accrue permanent Global Admins, RBAC sprawl, orphaned guests, and rework. Designing first — deciding topology, identity model, access model, and governance on purpose, and recording the decisions — makes the build predictable and the result defensible.

Why identity is the control plane

In a Microsoft cloud estate, identity is where trust is established and access is enforced. Every sign-in, every admin action, every app connection, and every automated workload authenticates through Microsoft Entra. Get the identity architecture right and the rest of Zero Trust (devices, data, network, apps) has a solid anchor; get it wrong and every downstream control inherits the weakness. That is why a secure cloud identity foundation is worth designing deliberately, once.

The six design domains

The architecture is organized into six domains. Each domain produces decisions in the Decision Record and maps to the implementation solution that builds it:

1. **Tenant topology & environment model** — single vs. multi-tenant, production/test separation,

directory boundaries, and the source of authority for identity (cloud-only vs. hybrid).

1. **Identity model (human / workload / external)** — the three identity types and how each is represented, named, provisioned, and retired: member users (humans), service principals / managed identities (workloads), and B2B guests / cross-tenant access (external).

1. **Zero Trust access design** — the Conditional Access persona baseline and the Identity Protection risk posture (the "who, on what, how risky" access rules). *Builds:* the Zero Trust Conditional Access Baseline and Identity Protection solutions.

1. **Privileged access model** — admin tiering, PIM eligibility and activation, break-glass, and privileged access workstations (PAW). *Builds:* the PIM and PAW solutions.

1. **Identity governance model** — joiner/mover/leaver lifecycle, entitlement management (access packages), and access reviews. *Build:* the Identity Governance solution.

1. **Hybrid / coexistence & connectivity** — on-prem AD coexistence (Entra Connect / cloud sync), application identity and migration, and secure network access to resources (Global Secure Access). *Builds:* the Hybrid Identity, Application Migration, and Global Secure Access solutions.

How the blueprint relates to the builds (this is a design product)

This solution deliberately does **not** re-document how to configure Conditional Access, PIM, access reviews, or Entra Connect — those are delivered, click-by-click, by the adjacent catalog solutions. This blueprint's job is upstream of them: decide the target state, record the decisions, and sequence the builds. Each domain in the Design Guide ends with a "build cross-reference" naming the implementation solution that executes it, so the buyer's roadmap is a concrete, ordered list of the solutions to deploy — not a vague aspiration.

Design domain	Implementation solution it points to (the build)
Zero Trust access — Conditional Access baseline	Zero Trust Conditional Access Baseline (`ENTZTCA`)
Zero Trust access — risk-based (P2)	Identity Protection & Advanced Conditional Access (`ENTIDP`)
Privileged access — just-in-time elevation	Privileged Identity Management / PIM (`ENTPIM`)
Privileged access — admin workstations	Privileged Access Workstation / PAW (`ENTPAW`)
Identity governance — reviews, entitlement, lifecycle	Identity Governance: Access Reviews & Entitlement (`ENTIGA`)
Connectivity — secure access to resources	Global Secure Access (`ENTGSA`)
Applications — identity & migration	Migrate & Protect Applications with Entra (`ENTAPPMIG`)
Hybrid coexistence — AD ↔ Entra sync	Hybrid Identity: AD + Entra Connect (`HYBID`)

The design method — Assess, Configure, Pilot, Validate, Expand

The same repeatable model the catalog uses, adapted for a design deliverable:

• **Assess** — inventory the current identity posture with the read-only scripts (humans, workloads, external identities, privileged access, Conditional Access, licensing). This is the evidence base.

• **Configure** — draft the target-state design across the six domains and capture each choice in the Decision Record as a numbered `ADR-0nn` with context, decision, rationale, and consequences.

• **Pilot** — run a structured design review with the decision owners (security, ops, compliance); test each decision against the architecture principles and the current-state evidence.

• **Validate** — check the design against explicit pass/fail gates and against the tenant with the validation script; confirm nothing conflicts with an existing control or license reality.

• **Expand** — finalize the Architecture Design Document, freeze the Decision Record, publish the phased Roadmap, and hand each phase to its build solution.

Naming and standards the design defines

So the design is legible and the builds inherit a consistent convention, the blueprint mandates the same object-naming pattern the implementation solutions already use — `<Purpose> - <Scope> - <Stage>` for groups and objects — plus a decision-record convention `ADR-0nn <Decision> - <Domain>` and a roadmap-phase convention `Phase n - <Theme>`. These names are defined once here and reused by every build.

Authentication and connections used

• Microsoft Entra admin center (`https://entra.microsoft.com`) and the Azure portal for read-only review of the current posture during Assess.

• Microsoft Graph PowerShell SDK and the Az module for the read-only discovery, inventory, posture reporting, privileged-access review, and validation scripts (each script's header names its scopes; all are read-only).

• KQL against Entra sign-in / audit logs (Log Analytics or the sign-in logs blade) for the posture evidence in the assessment report — read-only queries you paste and run.

What you can control

• The target-state design across all six domains.

• The Decision Record — every `ADR-0nn`, its rationale, and its license/preview caveats.

• The naming and admin-tiering standard the builds will adopt.

• The roadmap sequence and phase gates.

Benefits

• **Deliberate** — an identity foundation designed on purpose, with the rationale recorded, instead of accreted project by project.

• **Defensible** — a decision record you can show an auditor, a board, or a new architect: what was decided, why, and what it depends on.

• **Sequenced** — a phased roadmap that turns "secure our identity" into an ordered list of concrete builds, each cross-referenced to the solution that delivers it.

• **Repeatable** — the same Assess -> Configure -> Pilot -> Validate -> Expand shape as every build, so the design and the builds feel like one system.

Limitations (be honest with buyers)

• This is a **design deliverable**. It produces an architecture, a decision record, and a roadmap — it does **not** configure Conditional Access, PIM, governance, or sync. Those are the cross-referenced build solutions; budget and schedule them as separate phases.

• Several target-state controls depend on licensing — **Entra ID P1/P2**, **Entra ID Governance**, **Global Secure Access**, **Verified ID** — and some capabilities are **in preview**. The design flags each dependency; *verify current availability in your tenant* before committing a decision to it.

• Regulatory / records / legal retention, data classification, acceptable-identity-use, and production change-approval determinations are **the customer's** to make (compliance / security / legal / ops). The architecture provides the technical controls and the decision framework, not those determinations.

The standard deployment model

> *Assess the current identity posture (read-only scripts + KQL) -> Configure the target-state design and Decision Record across the six domains -> Pilot the design in a review with decision owners -> Validate against pass/fail gates and the tenant -> Expand into the finalized Design Document, Decision Record, and phased Roadmap handed to the build solutions. Repeatable pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

2. Requirements Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture

Verify every requirement before you begin the design work. Each entry: Description / Why / Verify / Implement-if-missing. Category-wide prerequisites (tenant, licensing, admin roles, break-glass accounts, healthy AD, Connect host, UPN hygiene, network access) are in `global-requirements-entra-id-solutions.md` — this guide adds only what is specific to producing the reference architecture. Because this is a **design deliverable**, most requirements are about **access to evidence and to decision owners**, not about standing up infrastructure.

2.1 Read-only access to the current tenant (for Assess)

Description: `Global Reader` (and `Security Reader`) on the production tenant, so the discovery, inventory, posture, and privileged-access scripts can read the current identity posture. Why: The design is

grounded in the actual current state — humans, workloads, guests, privileged roles, Conditional Access, licensing. Read-only roles keep the assessment safe and least-privilege. Verify: Entra -> `Roles and administrators`; confirm the operator holds `Global Reader` (and `Security Reader`). Run `ENTARCH-Discovery.ps1` — it should read without error and change nothing. Implement: Assign `Global Reader` + `Security Reader` (ideally PIM-eligible). No write roles are needed to produce the design.

2.2 Microsoft Graph PowerShell SDK and the Az module

Description: The Microsoft Graph PowerShell SDK and the Azure Az PowerShell module on the operator workstation, consented to read-only scopes. Why: All five scripts read posture through Microsoft Graph (identities, roles, policies, licensing) and, for subscription/RBAC context, through the Az module. They are the evidence engine for Assess and the validation engine for Validate. Verify: `Get-Module -ListAvailable Microsoft.Graph.Authentication` and `Get-Module -ListAvailable Az.Accounts` each return a version; a test `Connect-MgGraph` succeeds. Implement: `Install-Module Microsoft.Graph -Scope CurrentUser` and `Install-Module Az -Scope CurrentUser`. Scripts request least privilege (for example `Directory.Read.All`, `Policy.Read.All`, `RoleManagement.Read.Directory`, `AuditLog.Read.All`, `Application.Read.All`).

2.3 Access to Entra sign-in and audit logs (for the posture KQL)

Description: Read access to Entra sign-in and audit logs — in the portal (`Monitoring -> Sign-in logs`) and, if streamed, in a Log Analytics workspace for the KQL queries. Why: The assessment quantifies the real posture — MFA coverage, legacy-auth usage, risky sign-ins, privileged sign-in patterns — which drives several architecture decisions. Sign-in log retention and KQL both benefit from Entra ID P1+ and (for longer history) a Log Analytics workspace. Verify: `Monitoring -> Sign-in logs` returns recent events; if using KQL, the Log Analytics workspace has the `SigninLogs` / `AuditLogs` tables populated. Implement: Confirm Entra ID P1+ for sign-in log access; if you want history beyond the built-in retention, configure `Diagnostic settings` to stream `SignInLogs` and `AuditLogs` to a Log Analytics workspace. *Verify current retention and licensing in your tenant.*

2.4 A current licensing and product inventory

Description: A clear picture of which identity licenses the tenant actually holds — Entra ID P1/P2, Entra ID Governance, Global Secure Access, Verified ID — and any add-ons. Why: The target-state design must be honest about license reality: risk-based Conditional Access and PIM need **P2**; entitlement management and lifecycle workflows need **Entra ID Governance**; Global Secure Access and Verified ID are **separately licensed / partly in preview**. Decisions that assume an unlicensed feature are not defensible. *Verify current availability in your tenant.* Verify: Run `ENTARCH-Discovery.ps1` (licensing section) and cross-check M365 admin center -> `Billing -> Licenses`. Implement: Record the true license position; where a target-state decision needs a license the tenant lacks, either flag it as a roadmap prerequisite (acquire the license) or design an interim P1-only alternative and note the gap.

2.5 Named decision owners (the design cannot be made for them)

Description: Named owners from **security**, **IT operations**, and **compliance/legal** who own the determinations the architecture must not make unilaterally. Why: Tenant topology, what counts as "privileged," data-residency and regulatory constraints, acceptable external-collaboration posture, and

change-approval are **business/security/compliance decisions**. The architect frames the options and the tradeoffs; these owners decide, and their decisions become ADR-0nn entries with an owner attributed. Verify: Each of the six design domains has a named accountable owner recorded before the Configure stage. Implement: Identify the owners at kickoff; if a domain has no owner, that is itself a finding — the design records the open decision rather than inventing an answer.

2.6 Inventory of existing identity controls (avoid re-deciding what exists)

Description: Knowledge of what identity controls already exist — current Conditional Access policies, any PIM configuration, existing governance (access reviews/access packages), current hybrid sync, and existing break-glass accounts. Why: This is a **gap-only** design. Where a control already exists and is sound, the architecture adopts it (and records why); it does not rebuild it. The scripts surface what is already there so the roadmap targets only the gaps. Verify: Run ENTARCH-Discovery.ps1 and ENTARCH-PrivilegedAccessReview.ps1; review the existing CA policies, PIM assignments, and break-glass accounts they list. Implement: Capture the current-state inventory as the "Assess" appendix of the Design Document; each existing control is either **adopt**, **adjust**, or **replace** in the Decision Record.

2.7 Break-glass accounts (design prerequisite, not a build here)

Description: At least two cloud-only emergency access accounts (global requirement G4) — the design assumes and mandates them, and the privileged-access domain records their standard. Why: The privileged access model depends on break-glass being the anti-lockout guarantee behind every future Conditional Access and PIM build. The architecture defines the standard even though the builds implement the exclusions. Verify: Entra -> Users; confirm two cloud-only @onmicrosoft.com accounts; ENTARCH-PrivilegedAccessReview.ps1 lists them. Implement: If missing, create them (per G4) and record the break-glass standard as an ADR. Do not proceed to design the privileged access model without them.

2.8 A place to author the design artifacts

Description: A location to author and version the three deliverables — the Architecture Design Document, the Decision Record, and the Roadmap (a document library, repo, or wiki). Why: A reference architecture is only useful if it is versioned, reviewable, and durable. The Decision Record in particular is a living log that outlives any single build. Verify: The team has a versioned home for the three artifacts, with the decision owners able to review. Implement: Use the organization's standard docs location; keep the Decision Record under version control so each ADR change is traceable.

Checklist

- Global Reader + Security Reader on the production tenant (read-only) — ENTARCH-Discovery.ps1 runs clean
- Microsoft Graph SDK and Az module installed and consented (read-only scopes)
- Sign-in / audit log access (portal, and Log Analytics if using the posture KQL)
- True licensing position recorded (P1/P2, Governance, GSA, Verified ID) — *verify availability*
- Named decision owners for all six domains (security / ops / compliance)

- Existing identity controls inventoried — adopt / adjust / replace decided per control
- Two cloud-only break-glass accounts confirmed (global requirement G4)
- Versioned home for the Design Document, Decision Record, and Roadmap

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve

AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Design & Decision Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture

This is a **design deliverable**, so this guide is a **method for producing a documented architecture**, not a click-by-click deployment. Follow the stages in order. The output is three named artifacts: the **Architecture Design Document**, the **Decision Record** (a numbered log of `ADR-0nn` decisions), and the **phased Roadmap**. The actual configuration of each control is performed later by the cross-referenced build solution, not here.

> *Method: Assess the current identity posture with the read-only scripts and KQL -> Configure the target-state design across the six domains, recording each choice as an `ADR-0nn` -> Pilot the design in a structured review with the decision owners -> Validate against pass/fail gates and the tenant -> Expand into the finalized Design Document, frozen Decision Record, and published Roadmap. No decision is finalized before it is reviewed and validated, and every domain ends with a build cross-reference.*

Artifact & object naming convention (used everywhere below and in the scripts):

Artifact / object	Name
Master design document	`Identity Architecture - Enterprise - Design`
Decision log	`Decision Record - Identity Architecture - Design`
Individual decision	`ADR-0nn <Decision> - <Domain>`
Roadmap	`Roadmap - Identity Foundation - Phased`
Roadmap phase	`Phase n - <Theme>`
Groups/objects the design mandates (for the builds)	`<Purpose> - <Scope> - <Stage>`
Admin tiers the design defines	`Tier 0 / Tier 1 / Tier 2`

Create these once and reuse the exact names in the Testing Guide, Troubleshooting Guide, and scripts.

Stage 1 (Assess) — inventory the current identity posture

1. Run `ENTARCH-Discovery.ps1`. It reports, read-only: verified domains and topology signals, the

identity source of authority (cloud-only vs. synced), licensing (P1/P2, Governance, GSA, Verified ID — flagged *verify*), existing Conditional Access policies and states, named locations, and external-collaboration settings.

1. Run `ENTARCH-IdentityInventory.ps1`. It counts and profiles the three identity types: **human**

(member users, stale accounts, MFA registration), **workload** (service principals, managed identities, app credentials nearing expiry), and **external** (B2B guests, guest age, cross-tenant settings).

1. Run `ENTARCH-PrivilegedAccessReview.ps1`. It enumerates privileged role assignments — permanent vs.

PIM-eligible, the Global Administrator count, highly-privileged service principals, and whether break-glass accounts exist.

1. Run `ENTARCH-Report.ps1` and run the embedded **KQL** queries (against `Monitoring -> Sign-in logs`

or a Log Analytics workspace) to quantify posture: MFA coverage, legacy-auth sign-ins, risky sign-ins, and privileged sign-in patterns.

1. Save all output as the **Assess appendix** of `Identity Architecture - Enterprise - Design`. This is

the evidence base — every decision that follows cites it. For each existing control, tag it **adopt**, **adjust**, or **replace** (this keeps the design gap-only — you do not redesign what is already sound).

Stage 2 (Configure) — design the six domains and record the decisions

Work through the six domains in order. For each, frame the options against the architecture principles (below), pick a target state with the named decision owner, and write an `ADR-0nn` capturing **Context /**

Decision / Rationale / Consequences / License-or-preview caveat / Build cross-reference.

Architecture principles (the design is tested against these): least privilege by default; assume breach (Zero Trust); no permanent standing admin; break-glass is sacrosanct; phishing-resistant auth for privileged access; govern the full identity lifecycle; prefer cloud-native over hybrid where feasible; every exception is documented, owned, and time-boxed.

Domain 1 — Tenant topology & environment model

- Decide single vs. multi-tenant, production/test separation, and directory boundaries.
- Decide the **source of authority**: cloud-only, or hybrid with on-prem AD as master (drives Domain 6).
- Decisions: `ADR-001 Tenant Topology - Foundation`, `ADR-002 Identity Source of Authority - Foundation`.

Domain 2 — Identity model (human / workload / external)

- **Human:** UPN/naming standard (routable domain, no `.local`), account types (member / cloud-only admin), and joiner/mover/leaver ownership. Object standard example: `<Purpose> - <Scope> - <Stage>` security groups (for example `CA Persona - Admins - Steady`, reused by the Zero Trust build).
- **Workload:** how service principals and managed identities are named, owned, credential-managed, and governed (prefer managed identities and short-lived credentials; app-credential expiry monitoring).
- **External:** the B2B collaboration and cross-tenant access posture — who can invite, which external tenants are trusted, and guest lifecycle (access reviews + expiry).
- Decisions: `ADR-003 Human Identity & Naming Standard - Identity Model`, `ADR-004 Workload Identity Strategy - Identity Model`, `ADR-005 External Identity & B2B Posture - Identity Model`.
- Build cross-reference: External Identities / B2B Cross-Tenant and Enterprise App & Service Principal Governance solutions execute the workload and external decisions.

Domain 3 — Zero Trust access design

- Design the **Conditional Access persona baseline**: personas (`Admins`, `Internals`, `Externals-Guests`, `Service-Accounts`) mapped to `<Purpose> - <Scope> - <Stage>` groups, the control per persona (MFA, phishing-resistant for admins, compliant/hybrid device, block legacy auth, session controls), and the report-only-first rollout discipline. This design is the input the build consumes; it does not create the policies here.
- Design the **Identity Protection risk posture** (sign-in risk / user risk policies) — **requires Entra ID P2**; *verify availability*. If P1-only, design the non-risk compensating controls and note the gap.
- Decisions: `ADR-006 Authentication Methods & Phishing-Resistant Strategy - Zero Trust`, `ADR-007 Conditional Access Persona Baseline - Zero Trust`, `ADR-008 Identity Protection Risk Posture (P2) - Zero Trust`.

• **Build cross-reference:** the **Zero Trust Conditional Access Baseline (**`ENTZTCA`**)** builds the CA baseline; **Identity Protection & Advanced Conditional Access (**`ENTIDP`**)** builds the risk posture.

Domain 4 — Privileged access model

• Design **admin tiering** (`Tier 0` = identity/control-plane admins; `Tier 1` = server/workload admins; `Tier 2` = workstation/helpdesk), with role separation and no cross-tier credential reuse.

• Design the **PIM model**: which roles are eligible (not permanent), activation requirements (approval, MFA, justification, max duration) — **requires Entra ID P2**; *verify availability*.

• Design the **break-glass standard** (two cloud-only accounts, excluded from CA, monitored) and the **PAW model** (privileged access workstations for Tier 0/1 admin work).

• Decisions: `ADR-009 Admin Tiering Model - Privileged Access`, `ADR-010 PIM Eligibility & Activation Model - Privileged Access`, `ADR-011 Break-Glass Standard - Privileged Access`, `ADR-012 Privileged Access Workstation Model - Privileged Access`.

• **Build cross-reference: Privileged Identity Management (**`ENTPIM`**)** builds PIM; **Privileged Access Workstation (**`ENTPAW`**)** builds the PAW. Break-glass exclusions are implemented by the Zero Trust build (`ENTZTCA`).

Domain 5 — Identity governance model

• Design the **joiner/mover/leaver (JML) lifecycle** (automated provisioning/deprovisioning triggers), **entitlement management** (access packages with policies, approvals, and expiry), and **access reviews** (cadence and scope for privileged roles, guests, and high-value groups). **Requires Entra ID Governance**; *verify availability*.

• Decisions: `ADR-013 Access Lifecycle (JML) - Governance`, `ADR-014 Entitlement Management & Access Packages - Governance`, `ADR-015 Access Reviews Cadence - Governance`.

• **Build cross-reference: Identity Governance: Access Reviews & Entitlement (**`ENTIGA`**)** builds the governance model.

Domain 6 — Hybrid / coexistence & connectivity

• Design **hybrid coexistence** if the source of authority is on-prem AD (Entra Connect vs. cloud sync, source anchor, password hash sync vs. pass-through vs. federation) — see the category global requirements (healthy AD, Connect host, UPN hygiene).

• Design **application identity & migration** (moving apps to Entra SSO, retiring legacy auth) and **secure network access to resources** (Global Secure Access) — **GSA is separately licensed / partly in preview**; *verify availability*.

• Decisions: `ADR-016 Hybrid Coexistence & Sync Model - Hybrid`,

`ADR-017 Application Identity & Migration Approach - Apps`, `ADR-018 Secure Network Access (Global Secure Access) - Connectivity`.

- **Build cross-reference: Hybrid Identity: AD + Entra Connect (**`HYBID`**)**,

Migrate & Protect Applications with Entra (`ENTAPPMIG`**)**, and **Global Secure Access (**`ENTGSA`**)**.

Stage 3 (Pilot) — design review with the decision owners

1. Convene the named decision owners (security, ops, compliance). Walk the Decision Record `ADR` by

`ADR`.

1. For each decision confirm: it is consistent with the architecture principles; it does not conflict

with an existing **adopt** control from Assess; its license/preview caveat is acknowledged and owned; and an accountable owner is attributed.

1. Record objections and open decisions **as** `ADR` entries in `Proposed` status — never invent an

answer where an owner has not decided. The design captures the open question.

Stage 4 (Validate) — check the design against gates and the tenant

1. Run `ENTARCH-Validate.ps1`. It checks the tenant against the target-state blueprint: are break-glass

accounts present; do the mandated `<Purpose> - <Scope> - <Stage>` design groups exist yet (or are they roadmap items); is the licensing the design assumes actually present; are there All-users CA policies with no exclusions that the design must reconcile.

1. Complete the Testing Guide (`05-testing.md`) — every `ADR` has context+rationale, every domain has a

build cross-reference, every license/preview dependency is flagged *verify*, and the roadmap phases are gated.

1. Reconcile any gap the validation surfaces: either adjust the decision, or record it as an explicit

roadmap prerequisite (for example "acquire Entra ID P2 before Phase 2").

Stage 5 (Expand) — finalize and roadmap

1. Freeze the **Decision Record** — move every reviewed `ADR` from `Proposed` to `Accepted` (or record

why it was `Rejected` / `Superseded`). The frozen record is the defensible artifact.

1. Publish the **phased Roadmap** `Roadmap - Identity Foundation - Phased`, sequencing the builds:

Phase	Theme	Builds (cross-referenced solutions)	Gate to enter
`Phase 0 - Foundation`	Break-glass, tenant/topology, licensing true-up	Break-glass standard; license acquisition where needed	Assess complete; owners named

Phase	Theme	Builds (cross-referenced solutions)	Gate to enter
`Phase 1 - Hybrid & Identity Model`	Source of authority, sync, human/workload/external model	`HYBID`; External Identities / App governance	`ADR-001..005`, `016` accepted
`Phase 2 - Zero Trust Access`	CA persona baseline, then risk posture	`ENTZTCA`, then `ENTIDP` (P2)	`ADR-006..008` accepted; P1/P2 confirmed
`Phase 3 - Privileged Access`	Admin tiering, PIM, PAW	`ENTPIM`, `ENTPAW`	`ADR-009..012` accepted; P2 confirmed
`Phase 4 - Governance`	JML lifecycle, entitlement, access reviews	`ENTIGA`	`ADR-013..015` accepted; Governance license confirmed
`Phase 5 - Apps & Connectivity`	App migration, Global Secure Access	`ENTAPPMIG`, `ENTGSA`	`ADR-017..018` accepted; GSA availability verified

1. Hand each phase to its build solution. Keep the Decision Record living — every future build that deviates adds a superseding `ADR` rather than silently drifting.

Order of operations

```
Assess (posture scripts + KQL) -> Configure (six domains -> Decision Record ADRs) -> Pilot (owner review) -> Validate (gates + ENTARCH-Validate.ps1 against the tenant) -> Expand (freeze Decision Record + publish phased Roadmap -> hand to build solutions)
```

Rollback / reversibility (a design product)

• Because this deliverable **makes no tenant changes**, there is nothing to roll back. The scripts are read-only; the output is documentation.

• A **decision** is reversed by adding a superseding `ADR` (status `Superseded`) — the Decision Record keeps the history, so the architecture never drifts silently.

• The **builds** it hands off to each carry their own report-only / `-WhatIf` / break-glass rollback discipline (see each build solution); the roadmap's phase gates ensure no build enforces before its design decision is accepted and validated.

5. Testing Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture

Because this is a **design deliverable**, "testing" validates two things: (1) the **evidence base** the scripts produced during Assess is complete and read-only, and (2) the **design artifacts** — the Architecture Design Document, the Decision Record, and the Roadmap — are complete, defensible, and gated. Scripts are referenced by name; all reads are read-only.

Test 1 — Assess evidence is complete

Do: Confirm `ENTARCH-Discovery.ps1`, `ENTARCH-IdentityInventory.ps1`, `ENTARCH-PrivilegedAccessReview.ps1`, and `ENTARCH-Report.ps1` all ran and their output is saved as the Assess appendix of `Identity Architecture - Enterprise - Design`. Expected: Topology, licensing, the three identity types, privileged access, and posture (MFA / legacy auth / risk) are all documented. No script made any change (read-only).

Test 2 — Every existing control is classified

Do: Review the Assess appendix. Expected: Each existing identity control (Conditional Access policy, PIM config, governance, sync, break-glass) is tagged **adopt**, **adjust**, or **replace** — nothing is left unclassified, so the design stays gap-only.

Test 3 — The Decision Record covers all six domains

Do: Review `Decision Record - Identity Architecture - Design`. Expected: Every domain (Topology, Identity Model, Zero Trust, Privileged Access, Governance, Hybrid/Connectivity) has at least one `ADR-0nn`. No domain is missing a decision or an owner.

Test 4 — Each ADR is complete and defensible

Do: Spot-check each `ADR-0nn`. Expected: Each has Context / Decision / Rationale / Consequences / License-or-preview caveat / Build cross-reference, and a named accountable owner. Open questions are recorded as `Proposed`, not invented.

Test 5 — License and preview dependencies are flagged

Do: Search the Design Document and Decision Record for every feature that needs P2, Entra ID Governance, Global Secure Access, or Verified ID, or that is in preview. Expected: Each is explicitly flagged with *verify current availability in your tenant*, and any decision depending on an unheld license is either a roadmap prerequisite or has a documented P1-only alternative.

Test 6 — Break-glass standard is in the design

Do: Review the privileged access domain and run `ENTARCH-PrivilegedAccessReview.ps1`. Expected: The design mandates two cloud-only break-glass accounts; the script confirms they exist (or the design records creating them as `Phase 0 - Foundation`).

Test 7 — The blueprint validates against the tenant

Do: Run `ENTARCH-Validate.ps1`. Expected: PASS/WARN lines for break-glass presence, the mandated design groups (present or roadmap), the assumed licensing, and any All-users CA policy without exclusions the design must reconcile. Every WARN is either resolved or captured as a roadmap prerequisite.

Test 8 — Every domain has a build cross-reference

Do: Review the Design Document domain by domain. Expected: Each domain names the implementation solution that builds it (`ENTZTCA`, `ENTIDP`, `ENTPIM`, `ENTPAW`, `ENTIGA`, `ENTGSA`, `ENTAPPMIG`, `HYBID`) — the roadmap is concrete builds, not aspirations.

Test 9 — The roadmap is phased and gated

Do: Review `Roadmap - Identity Foundation - Phased`. Expected: Phases 0–5 each list their builds and an explicit **gate to enter** (accepted ADRs / license confirmed). No phase can start before its design decisions are accepted and validated.

Test 10 — Decision Record is frozen and living

Do: Confirm the Expand stage completed. Expected: Every reviewed ADR is `Accepted` / `Rejected` / `Superseded` (none left `Proposed` at hand-off), and the record is under version control so future deviations add a superseding ADR rather than drifting silently.

Pass/fail gate

Gate	Requirement
Assess pass	Tests 1–2 pass; posture evidence complete and read-only; every existing control classified adopt/adjust/replace
Design pass	Tests 3–6 pass; all six domains decided, each ADR complete with owner and license/preview caveat; break-glass mandated
Validate & roadmap pass	Tests 7–10 pass; blueprint validated against the tenant; every domain has a build cross-reference; roadmap phased and gated; Decision Record frozen

6. Troubleshooting Guide — Microsoft Entra: Secure Cloud Identity Reference Architecture

This is a **design deliverable**, so the "failures" are mostly failures of *evidence gathering* and *design completeness*, not tenant outages. Use `ENTARCH-Discovery.ps1` for the current posture, `ENTARCH-IdentityInventory.ps1` and `ENTARCH-PrivilegedAccessReview.ps1` for the identity and privileged inventories, `ENTARCH-Report.ps1` (and its KQL) for posture metrics, and `ENTARCH-Validate.ps1` to check the blueprint against the tenant. All scripts are read-only.

A. Assessment scripts fail to connect or read

Symptom	Cause	Remediation
`Connect-MgGraph` fails or scopes missing	Graph SDK not installed, or read scopes not consented	`Install-Module Microsoft.Graph -Scope CurrentUser`; re-run and accept the read-only scopes (`Directory.Read.All`, `Policy.Read.All`, `RoleManagement.Read.Directory`, `AuditLog.Read.All`, `Application.Read.All`)
`Connect-AzAccount` fails	Az module missing or no subscription context	`Install-Module Az -Scope CurrentUser`; sign in; the subscription/RBAC section is optional context — skip if no Azure subscription
Reads return little/nothing	Operator lacks `Global Reader` / `Security Reader`	Assign the read-only roles (requirement 2.1); confirm you are in the correct tenant

B. Posture / KQL evidence is thin or empty

Symptom	Cause	Remediation
Sign-in KQL returns nothing	Logs not streamed to Log Analytics, or short retention	Query the portal `Monitoring -> Sign-in logs` directly, or configure `Diagnostic settings` to stream `SignInLogs`/`AuditLogs`; widen the time range
MFA-coverage numbers look wrong	Mixed per-user MFA and Conditional Access, or registration vs. enforcement confusion	Read registration from the authentication-methods report and enforcement from CA; the report distinguishes them — do not conflate "registered" with "required"
Legacy-auth count is zero but you expected some	Legacy auth may already be blocked, or the lookback is too short	Confirm existing CA legacy-auth block from Discovery; widen `-LookbackDays`; a true zero is a good finding — record it

C. Licensing reality does not match the design's assumptions

- The most common design flaw: an ADR assumes **P2**, **Entra ID Governance**, **Global Secure

Access**, or** Verified ID** the tenant does not hold. `ENTARCH-Discovery.ps1` reports the true license position. Fix the design, not the tenant: either make license acquisition an explicit `Phase 0`/roadmap prerequisite, or design a documented P1-only interim and note the gap. Always flag the dependency

verify current availability in your tenant — bundles and preview status change.

D. A decision has no owner / the design stalls

- A domain with no named accountable owner is a finding, not a blocker. Record the decision as

`ADR-0nn ... - <Domain>` in `Proposed` status with the open question stated, and escalate to get an owner. Never invent the answer to keep moving — an unowned invented decision is worse than a documented open one.

E. The design conflicts with an existing control

Symptom	Cause	Remediation
New design contradicts a live CA policy or PIM config	Assess did not classify the existing control	Go back to Stage 1: tag every existing control **adopt / adjust / replace**; reconcile the `ADR` against the adopt set so the design is gap-only, not a silent overwrite
Two ADRs disagree	Decisions made in different domains without cross-check	Cross-reference the conflicting `ADR`s; supersede the weaker one with a new `ADR` (status `Superseded`) — keep the history

F. `ENTARCH-Validate.ps1` flags gaps

Symptom	Cause	Remediation
Break-glass not found	No emergency accounts exist yet	Design mandates two cloud-only accounts; record their creation as `Phase 0 - Foundation`; do not finalize the privileged-access domain without them
Mandated design groups missing	They are roadmap items, not yet built	Expected before the builds run — the validation distinguishes "missing (roadmap)" from "missing (should exist)"; confirm they are scheduled in the roadmap
All-users CA policy with no exclusions	A pre-existing lock-out risk the design must reconcile	Flag it in the Zero Trust domain; the `ENTZTCA` build fixes it (exclude break-glass) — record the reconciliation as an `ADR`

G. The blueprint is treated as the build (scope confusion)

- Symptom: a stakeholder expects Conditional Access, PIM, or governance to be *configured* by this

deliverable. Cause: this is the **design**, not the build. Remediation: point to the domain's build cross-reference and the roadmap phase — the configuration is delivered by `ENTZTCA` / `ENTPIM` / `ENTIGA` etc. Set this expectation at kickoff (see the Solution Overview "this is a design product").

H. Diagnostics quick reference

```
# Confirm read-only Graph context and the true licensing position
Connect-MgGraph -Scopes 'Directory.Read.All','Policy.Read.All','RoleManagement.Read.Directory' -NoWelcome
((Invoke-MgGraphRequest -Method GET -Uri '/v1.0/subscribedSkus').value).servicePlans.servicePlanName |
  Where-Object { $_ -match 'AAD_PREMIUM|Governance|GLOBAL_SECURE_ACCESS|Verified' } | Sort-Object -Unique
# Count permanent (non-PIM) privileged role assignments — a key design driver
(Invoke-MgGraphRequest -Method GET -Uri '/v1.0/roleManagement/directory/roleAssignments?$count=true' -Head
```

I. When to escalate

This deliverable changes nothing in the tenant, so there is no outage to escalate. Escalate instead when a **design decision** cannot be made because an owner is unavailable or a regulatory/data-residency constraint is unclear — that is a business/compliance escalation, and the architecture records the open ADR until it is resolved. If the Assess scripts reveal an **active** security problem (for example a surge of risky sign-ins or a suspicious privileged assignment), treat that as a security incident on its own track — do not wait for the design to complete.

7. Best Practices — Microsoft Entra: Secure Cloud Identity Reference Architecture

- Design before you build, always. The whole value of this deliverable is that topology, identity

model, access, privileged access, and governance are decided on purpose and recorded — before a single policy is created. A tenant that builds first and designs never is exactly the ad-hoc estate this solution exists to prevent.

- Ground every decision in evidence. Run the read-only Assess scripts and the posture KQL first; each

`ADR-0nn` should cite the current-state finding it responds to. Design from data, not assumption.

- Keep it gap-only. Where an existing control is sound, tag it **adopt** and record why — do not

redesign what already works. The architecture targets the gaps, and the roadmap sequences only the builds the tenant actually needs.

- Record the rationale, not just the choice. A Decision Record's worth is the *why* and the

consequences — an auditor, a board, or the next architect must be able to see what was decided, why, and what it depends on. A decision with no rationale is not defensible.

- Let the owners own the determinations. Tenant topology, what counts as "privileged," data-residency

and regulatory constraints, external-collaboration posture, and change-approval are security/compliance/business decisions — the architect frames the options; the named owner decides, and the ADR attributes them. Never invent an answer where an owner has not decided; record the open question as `Proposed`.

- Be honest about licensing and preview. Risk-based Conditional Access and PIM need **Entra ID P2**;

entitlement management and lifecycle need **Entra ID Governance**; **Global Secure Access** and **Verified ID** are separately licensed and partly in preview. Flag every dependency with *verify current availability in your tenant*, and either make license acquisition a roadmap prerequisite or design a documented interim alternative.

• Make break-glass sacrosanct in the design. Two cloud-only emergency accounts, excluded from Conditional Access, monitored — the design mandates them as the anti-lockout guarantee behind every future build, even though the builds implement the exclusions.

• Design privileged access as tiers with no standing admin. Tier 0/1/2 separation, PIM eligibility instead of permanent roles, phishing-resistant auth for admins, and PAWs for Tier 0/1 work — this is the highest-leverage part of the architecture; get it decided early (`Phase 3`).

• Prefer cloud-native over hybrid where feasible. If the source of authority can be cloud-only, the design is simpler and the attack surface smaller; only carry hybrid coexistence where the business genuinely needs on-prem AD as master, and record why.

• Number and name everything consistently. `ADR-0nn <Decision> - <Domain>`, `Phase n - <Theme>`, and `<Purpose> - <Scope> - <Stage>` for the objects the builds will create — a self-documenting design the builds inherit without reinterpretation.

• Cross-reference every domain to its build. The roadmap must be a concrete, ordered list of the implementation solutions to deploy (`ENTZTCA`, `ENTIDP`, `ENTPIM`, `ENTPAW`, `ENTIGA`, `ENTGSA`, `ENTAPPMIG`, `HYBID`) — not a set of good intentions.

• Keep the Decision Record living. When a future build needs to deviate, add a **superseding** `ADR` rather than editing history or drifting silently. The record's integrity is what keeps the architecture true over years.

• Re-assess on a cadence. Re-run the read-only Assess scripts periodically; an architecture is a living design — new identity types, new licenses, and preview-to-GA transitions all warrant a superseding decision.

Where to go next

The roadmap this blueprint produces hands each phase to a build solution:

• **Zero Trust Conditional Access Baseline (**`ENTZTCA`**)** and **Identity Protection & Advanced Conditional Access (`ENTIDP`)** — build the Zero Trust access design (Domain 3).

• **Privileged Identity Management / PIM (**`ENTPIM`**)** and **Privileged Access Workstation / PAW (`ENTPAW`)** — build the privileged access model (Domain 4).

• **Identity Governance: Access Reviews & Entitlement (**`ENTIGA`**)** — build the governance model (Domain 5).

• **Hybrid Identity: AD + Entra Connect (**`HYBID`**)**, **Migrate & Protect Applications with Entra

(ENTAPPMIG)**, and** Global Secure Access (ENTGSA)** — build hybrid coexistence, app identity, and secure connectivity (Domains 1 and 6).

- **External Identities / B2B Cross-Tenant** and **Enterprise App & Service Principal Governance** — build the external and workload identity decisions (Domain 2).

8. Deliverables Summary — Microsoft Entra: Secure Cloud Identity Reference Architecture

Documentation

Document	Purpose
Executive Summary	Business case, what a reference architecture is, and what is in the box
1. Solution Overview	What a reference architecture is, the six design domains, how the blueprint relates to the builds, and the design method
2. Requirements Guide	Every solution-specific input (read-only access, tooling, decision owners, licensing truth) with Verify / Implement-if-missing
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Design & Decision Guide	The method that produces the three artifacts — Architecture Design Document, Decision Record (ADR-0nn), and phased Roadmap — across all six domains, each cross-referenced to its build
5. Testing Guide	Validation of the evidence base and the design artifacts, with pass/fail gates
6. Troubleshooting Guide	Evidence-gathering and design-completeness issues and remediation
7. Best Practices	Field-proven design recommendations + where to go next (the builds)

PowerShell scripts (all read-only; Microsoft Graph / Az + KQL)

Script	What it does
ENTARCH-Discovery.ps1	Inventories the current identity posture — verified domains/topology signals, identity source of authority, licensing (P1/P2, Governance, GSA, Verified ID — flagged *verify*), existing Conditional Access policies, named locations, and external-collaboration settings (read-only)

Script	What it does
`ENTARCH-IdentityInventory.ps1`	Profiles the three identity types — human (members, stale accounts, MFA registration), workload (service principals, managed identities, credentials nearing expiry), and external (B2B guests, guest age, cross-tenant settings) (read-only)
`ENTARCH-PrivilegedAccessReview.ps1`	Enumerates privileged access — role assignments permanent vs. PIM-eligible, the Global Administrator count, highly-privileged service principals, and whether break-glass accounts exist (read-only)
`ENTARCH-Report.ps1`	Produces the identity posture & maturity report and emits the **KQL** queries (MFA coverage, legacy-auth, risky sign-ins, privileged sign-ins) to run against sign-in/audit logs — the evidence for the Decision Record (read-only)
`ENTARCH-Validate.ps1`	Checks the tenant against the target-state blueprint — break-glass presence, the mandated design groups (present or roadmap), the assumed licensing, and All-users CA policies without exclusions the design must reconcile (read-only)

What the buyer receives

- This design method and all its guides as a Word document and PDF.
- All five read-only PowerShell scripts (with embedded KQL) in a single ZIP.
- The output of running them: an **Architecture Design Document**, a **Decision Record** (`ADR-0nn`), and a **phased Roadmap** — the blueprint for a secure Entra cloud identity foundation.
- A repeatable process: Assess -> Configure -> Pilot -> Validate -> Expand.

Delivered as a Complete Solution Package (PDF + Word + scripts).

Outcome

A documented, defensible Entra identity architecture: a target-state design across six domains, a numbered decision record with rationale and license/preview caveats, a canonical naming and admin-tiering standard the builds reuse, and a phased roadmap that sequences the implementation solutions (`ENTZTCA`, `ENTIDP`, `ENTPIM`, `ENTPAW`, `ENTIGA`, `ENTGSA`, `ENTAPPMIG`, `HYBID`) — the identity foundation designed once, deliberately, before the risk and rework accrue.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTARCH-Discovery.ps1

Purpose: Read-only assessment that grounds the reference architecture in the tenant's real current state: verified domains and topology signals, the identity source of authority (cloud-only vs. synced/hybrid), the true licensing position (Entra ID P1/P2, Governance, Global Secure Access, Verified ID — each flagged *verify current availability*), existing Conditional Access policies and their states, named locations, and external-collaboration (B2B) settings. This is the evidence base for the Decision Record — it changes NOTHING. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTARCH-Discovery.ps1 Optional: -CsvPath .\entra-posture.csv to export the summary. Consents to Directory.Read.All, Policy.Read.All, Organization.Read.All, Domain.Read.All (all read-only). No changes are made. EXPECTED RESULTS A printed posture summary (domains, source of authority, licensing tier, CA policy inventory, named locations, external-collab posture). Optional CSV. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string]$CsvPath)

How to run: Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTARCH-Discovery.ps1 Optional: -CsvPath .\entra-posture.csv to export the summary. Consents to Directory.Read.All, Policy.Read.All, Organization.Read.All, Domain.Read.All (all read-only). No changes are made. EXPECTED RESULTS A printed posture summary (domains, source of authority, licensing tier, CA policy inventory, named locations, external-collab posture). Optional CSV. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string]$CsvPath)

ENTARCH-IdentityInventory.ps1

Purpose: Read-only inventory that informs the identity-model domain (Domain 2) of the architecture. It profiles the three identity types the design must account for: • HUMAN — member users, likely-stale accounts (no recent sign-in), and MFA registration. • WORKLOAD — service principals and managed identities, plus app credentials nearing expiry. • EXTERNAL — B2B guest users, guest account age, and the cross-tenant collaboration signal. The counts and highlights drive ADR-003/004/005 (human/workload/external identity decisions). It changes NOTHING. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTARCH-IdentityInventory.ps1 Optional: -StaleDays 90 (sign-in age that flags a human account as likely-stale) -CredExpiryDays 30 (app-credential expiry window to warn on) Consents to Directory.Read.All, User.Read.All, Application.Read.All, AuditLog.Read.All (all read-only). No changes are made. EXPECTED RESULTS Printed counts and highlights for human, workload, and external identities. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([int]$StaleDays = 90, [int]$CredExpiryDays = 30)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTARCH-IdentityInventory.ps1 Optional: -StaleDays 90 (sign-in age that flags a human account as likely-stale) -CredExpiryDays 30 (app-credential expiry window to warn on) Consents to Directory.Read.All, User.Read.All, Application.Read.All, AuditLog.Read.All (all read-only). No changes are made. EXPECTED RESULTS Printed counts and highlights for human, workload, and external identities. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param(

[int]$StaleDays = 90, [int]$CredExpiryDays = 30)

ENTARCH-PrivilegedAccessReview.ps1

Purpose: Read-only review that grounds the privileged-access domain (Domain 4) of the architecture. It enumerates: • Directory role assignments that are PERMANENT (active) vs. PIM-ELIGIBLE (just-in-time). • The Global Administrator population (Microsoft guidance: keep this small — a design driver). • Highly-privileged SERVICE PRINCIPALS holding sensitive app roles (e.g. directory write). • Whether cloud-only BREAK-GLASS accounts appear to exist (anti-lockout prerequisite, G4). Findings drive ADR-009..012 (tiering, PIM eligibility/activation, break-glass, PAW). It changes NOTHING. PIM eligibility reads require Entra ID P2 — *verify availability in your tenant*. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTARCH-PrivilegedAccessReview.ps1 Optional: -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to RoleManagement.Read.Directory, Directory.Read.All, User.Read.All (all read-only). No changes are made. EXPECTED RESULTS Printed counts of permanent vs. eligible privileged assignments, the GA count, privileged service principals, and a break-glass presence check. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string[]]$BreakGlassUpn)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTARCH-PrivilegedAccessReview.ps1 Optional: -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to RoleManagement.Read.Directory, Directory.Read.All, User.Read.All (all read-only). No changes are made. EXPECTED RESULTS Printed counts of permanent vs. eligible privileged assignments, the GA count, privileged service principals, and a break-glass presence check. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string[]]$BreakGlassUpn)

ENTARCH-Report.ps1

Purpose: Read-only reporting that produces the posture evidence for the Decision Record and prints the ready-to-run KQL queries the assessment relies on. It summarizes a maturity view across the six design domains (topology/source-of-authority, identity model, Zero Trust access, privileged access, governance, hybrid) from the Graph signals available, and then emits KQL you paste into Entra 'Monitoring -> Sign-in logs' (Log Analytics) to quantify: MFA coverage, legacy-auth sign-ins, risky sign-ins (P2 / Identity Protection), and privileged sign-in patterns. It changes NOTHING. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTARCH-Report.ps1 Optional: -EmitKqlOnly (skip Graph; just print the KQL block) Consents to Directory.Read.All, Policy.Read.All, AuditLog.Read.All (all read-only). The KQL requires SigninLogs/AuditLogs streamed to a Log Analytics workspace (Entra ID P1+). EXPECTED RESULTS A printed maturity summary and a KQL block. Nothing is modified. Paste the KQL into Log Analytics to complete the posture evidence for the Assess appendix. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). Verify current licensing/preview availability in your tenant* for any P2/Governance/GSA feature. > [CmdletBinding()] param([switch]$EmitKqlOnly)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTARCH-Report.ps1 Optional: -EmitKqlOnly (skip Graph; just print the KQL block) Consents to Directory.Read.All, Policy.Read.All, AuditLog.Read.All (all read-only). The KQL requires SigninLogs/AuditLogs streamed to a Log Analytics workspace (Entra ID P1+). EXPECTED RESULTS A printed maturity summary and a KQL block. Nothing is modified. Paste the KQL into Log Analytics to complete the posture evidence for the Assess appendix. .NOTES White-label —

Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). Verify current licensing/preview availability in your tenant* for any P2/Governance/GSA feature. > [CmdletBinding()] param([switch]$EmitKqlOnly)

ENTARCH-Validate.ps1

Purpose: Read-only validation used in Stage 4 (Validate). It compares the tenant to the blueprint's target-state assumptions and prints PASS / WARN per check: • Break-glass — two cloud-only *.onmicrosoft.com emergency accounts present (anti-lockout, G4). • Mandated design groups — the '<Purpose> - <Scope> - <Stage>' groups the design names exist yet, OR are correctly deferred to the roadmap (distinguishes "missing (roadmap)" from "missing (should exist)"). • Licensing — the licenses the design assumes (P1/P2, Governance, GSA, Verified ID) are actually present (*verify* — feature detection is a signal only). • Lock-out sweep — any existing All-users CA policy with NO exclusions the Zero Trust domain must reconcile. It changes NOTHING. It does not create groups, policies, or accounts — it only reports gaps for the Decision Record / roadmap. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTARCH-Validate.ps1 `-BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com` -DesignGroup 'CA Persona - Admins - Steady','CA Exclusion - Break-Glass - Steady' Optional: -RequireP2 -RequireGovernance (assert the design's license assumptions) Consents to Directory.Read.All, Policy.Read.All, User.Read.All, Group.Read.All (read-only). EXPECTED RESULTS PASS/WARN lines for break-glass, design groups, licensing, and the lock-out sweep. Every WARN is either resolved or captured as a roadmap prerequisite. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string[]]$BreakGlassUpn, [string[]]$DesignGroup = @('CA Exclusion - Break-Glass - Steady','CA Persona - Admins - Steady'), [switch]$RequireP2, [switch]$RequireGovernance)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTARCH-Validate.ps1 `-BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com` -DesignGroup 'CA Persona - Admins - Steady','CA Exclusion - Break-Glass - Steady' Optional: -RequireP2 -RequireGovernance (assert the design's license assumptions) Consents to Directory.Read.All, Policy.Read.All, User.Read.All, Group.Read.All (read-only). EXPECTED RESULTS PASS/WARN lines for break-glass, design groups, licensing, and the lock-out sweep. Every WARN is either resolved or captured as a roadmap prerequisite. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. Design/assessment helper (not a deployment script). > [CmdletBinding()] param([string[]]$BreakGlassUpn, [string[]]$DesignGroup = @('CA Exclusion - Break-Glass - Steady','CA Persona - Admins - Steady'), [switch]$RequireP2, [switch]$RequireGovernance)